



UCS503 EmPay SATURN05

Rhythmpreet Singh (1024170301)
Rahul Singh (1024170067)
Krrish Dhaneja (1024170080)
Navdeep Jain (1024170082)

TABLE OF CONTENTS

01

Introduction

02

Project Scope

03

Proposed Functions

04

Target Users

05

System Features

06

Interfaces

07

Performance Goals

08

Security Measures

09

Quality Attributes

10

Initial Planning

Introduction

Overview: Digital payments depend on continuous network connectivity to verify payers, authenticate transactions, and prevent double spending.

Importance: In situations such as network outages, crowded areas, or emergencies, users need to transfer payments locally. Bluetooth allows device-to-device communication in these scenarios.

Presentation Objectives: Evaluate protocol security, trace failure modes, and formally prove transaction invariants under explicit trust assumptions, specifically addressing double spending, replay attacks, cloned/rolled-back device states, and interrupted transfers.

Project Scope

Project Aims: Design, simulate, and verify EmPay - an offline-payment protocol simulator and adversarial verification platform to test and secure local transaction exchanges.

Deliverables: Build simulated offline payment components (issuer, payer, merchant) to trace failure modes and evaluate protocol security under explicit trust assumptions.

Functionality: Provide a simulation tool to model and test system robustness against double-spending, replay attacks, cloned device states, local rollback, and partial Bluetooth exchanges.

Proposed Functions

Major Functions: Simulated bank/issuer tracks transactions, including user balances, offline allocations, and device states.

User Needs: Handles user balance allocations (e.g., User balance: ₹30,000, offline allocation: ₹10,000, Device A: ₹6,000, Device B: ₹4,000).

Visualization: Simplifies ledger simulation by demonstrating device registration, revocation, transaction reconciliation, and authoritative settlement.

Target Users

Audience Description: Banks, small business owners, common people and organizations exploring secure offline digital payments.

User Characteristics: Small business owners and common people who need secure, reliable digital payments during limited or unavailable internet connectivity.

User Needs Impact: Enables secure offline payment transfers during network disruptions while reducing risks of double spending, replay attacks, and transaction loss.

System Features

Feature List: Android Merchant Application discovers nearby payers, receives transaction packets over Bluetooth, and displays transaction state.

Functionality Details: Verifies cryptographic signatures, checks transaction IDs , and detects duplicate or replayed messages.

Interfaces

Hardware/Software Interfaces: Android payer and merchant applications use the device's Bluetooth interface for local transaction exchange. Android Keystore provides protected storage and hardware-backed signing support where available.

Communication Interface: Transaction packets are exchanged locally between nearby payer and merchant devices over Bluetooth. The merchant application receives and verifies the packet before updating the transaction state.

Protocol Interface: The simulator models issuer, payer, and merchant components and supports transaction states including ABORTED, EXPIRED, RECOVERY, and REJECTED for failure and recovery handling.

Performance Goals

Requirements: Uses asymmetric key pairs, digital signatures, nonces, and unique IDs to guarantee payment authenticity and integrity.

Importance: Leverages Android Keystore to manage keys, testing and comparing Software-backed, TEE-backed, and StrongBox-backed storage.

Achievement Strategies: Integrates user PIN verification with hardware-backed signing to prevent unauthorized local spending.

Security Measures

Authentication & Integrity: Uses asymmetric key pairs and digital signatures to authenticate transaction data. Unique transaction IDs and nonces help detect duplicate, replayed, or reused messages.

Key Protection: Uses Android Keystore for key management, with Software-backed, TEE-backed, and StrongBox-backed storage considered. User PIN verification is used with hardware-backed signing to reduce unauthorized spending.

Transaction Protection: Enforces protocol checks for allocated and spent amounts, rejects invalid signatures, detects replay or duplicate transactions, and handles interrupted transfers through controlled recovery states.

Quality Attributes

Reliability: Represents the payment protocol as a formal state machine using TLA+/TLC model checker to verify critical properties.

Usability: Ensures that spent amount $\leq$ allocated, no double-settlement, invalid signatures are rejected, and nonces cannot be reused.

Maintainability: Proves that interrupted transactions reach a recoverable state and reconciliation cannot manufacture artificial value.

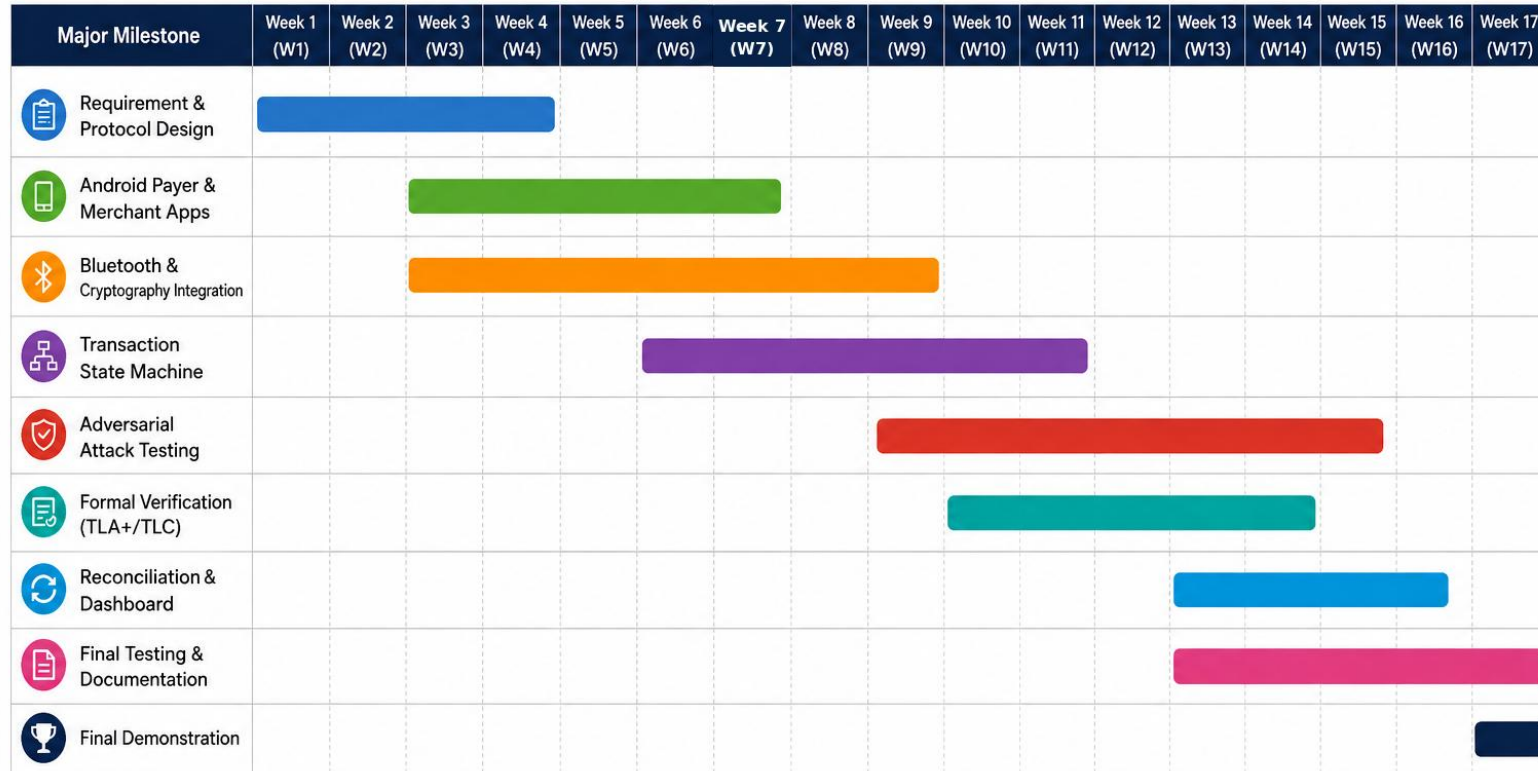
Initial Planning

Gantt Chart: A project scheduling tool that shows project tasks and milestones against time. The 17-week plan maps development, verification, testing, documentation, and the final demonstration.

Feasibility Report: Evaluates whether the proposed offline-payment simulator is technically, operationally, and security-wise feasible, considering Bluetooth communication, Android Keystore, TLA+/TLC, and planned testing.

Milestones: Define major checkpoints and deliverables, including protocol design, Android applications, cryptography integration, transaction-state implementation, adversarial testing, formal verification, reconciliation, final testing, and demonstration.

EmPay-Lab Project Gantt Chart (17 Weeks)



Timeline: 17 Weeks

Each week represents a major phase of development and evaluation.



Requirement & Protocol Design



Android Payer & Merchant Apps



Bluetooth & Cryptography Integration



Transaction State Machine



Adversarial Attack Testing



Formal Verification (TLA+/TLC)



Reconciliation & Dashboard



Final Testing & Documentation



Final Demonstration

Conclusion

Summary: Design, simulate, formally verify, and adversarially test an offline Bluetooth payment protocol.

Next Steps: Demonstrate a robust solution for offline allocation, double-spend prevention, failure recovery, and reconciliation.

Feedback Invitation: Provide a clear, documented framework outlining the exact trust boundaries and hardware security levels (TEE, StrongBox) required.

References

Sources: Academic research on secure offline transactions, TLA+/TLC model checking documentation, and Android Keystore (TEE/StrongBox) APIs.